



中华人民共和国通信行业标准

YD/T XXXXX—XXXX

电信网和互联网 数据安全评估技术实施指南

Technical implementation guide for data security assessment on telecom network
and Internet

(报批稿)

XXXX – XX – XX 发布

XXXX – XX – XX 实施

中华人民共和国工业和信息化部 发布

目 次

前 言.....	I
1 范围	1
2 规范性引用文件.....	1
3 术语和定义.....	1
4 数据安全评估概述	2
4.1 概述.....	2
4.2 数据安全评估原则	2
4.2.1 关键数据原则.....	2
4.2.2 场景依赖原则.....	2
4.2.3 可控性原则	2
4.2.4 最小影响原则.....	3
4.3 数据安全评估技术实施要点	3
4.4 数据安全评估技术实施流程	3
4.4.1 准备环境.....	4
4.4.2 实施现场评估.....	4
4.4.3 输出评估结果.....	5
4.4.4 问题整改.....	5
4.4.5 复评.....	5
5 数据安全评估技术实施方法.....	5
5.1 概述.....	5
5.2 数据梳理和分类.....	5
5.2.1 评估目的.....	5
5.2.2 评估方法.....	5
5.2.3 评估能力.....	5
5.3 存储加密.....	6
5.3.1 评估目的.....	6
5.3.2 评估方法.....	6
5.3.3 评估能力.....	6
5.4 传输加密.....	6
5.4.1 评估目的.....	6
5.4.2 评估方法.....	6
5.4.3 评估能力.....	6
5.5 权限管理.....	7
5.5.1 评估目的.....	7
5.5.2 评估方法.....	7
5.5.3 评估能力.....	7
5.6 数据脱敏.....	7
5.6.1 评估目的.....	7
5.6.2 评估方法.....	7
5.6.3 评估能力.....	8

5.7 日志审计	8
5.7.1 评估目的	8
5.7.2 评估方法	8
5.7.3 评估能力	9
5.8 脆弱性管理	9
5.8.1 评估目的	9
5.8.2 评估方法	9
5.8.3 评估能力	9
5.9 接口安全	9
5.9.1 评估目的	9
5.9.2 评估方法	9
5.9.3 评估能力	10
5.10 数据防泄漏	10
5.10.1 评估目的	10
5.10.2 评估方法	10
5.10.3 评估能力	10
6 数据安全评估技术实施环境	10
6.1 概述	10
6.2 数据梳理和分类	10
6.3 存储加密	10
6.4 传输加密	11
6.5 权限管理	11
6.6 数据脱敏	11
6.7 日志审计	11
6.8 脆弱性管理	11
6.9 接口安全	11
6.10 数据防泄漏	11

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草

本标准

是“电信网和互联网数据安全”系列标准之一。该系列标准预计结构及名称如下：

- 《电信网和互联网数据安全通用要求》（YD/T 3802-2020）
- 《电信网和互联网数据安全评估规范》（YD/T 3956-2021）
- 《电信网和互联网数据安全评估技术实施指南》（本文件）
- 《电信网和互联网数据资产识别与梳理技术实施指南》
- 《电信网和互联网数据安全日志审计指南》
- 《电信网和互联网数据生命周期日志留存指南》

请注意本文件的某些内容可能涉及专利，本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、中安威士（北京）科技有限公司。

本文件主要起草人：姜宇泽、张媛媛、庞妹、郭建南、戴林，王峰，罗杉、裴惠存。

电信网和互联网数据安全评估技术实施指南

1 范围

本文件提供以公用电信网和互联网网络单元以及业务系统中的数据为核心保护对象的、面向各种应用场景的数据安全评估方法参考。

本文件既可用于指导电信网和互联网企业数据安全评估中的风险评估、现有安全措施评估，也可单独用于指导监管部门、评估机构等组织开展数据安全评估工作。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本(包括所有的修改单)适用于本文件。

GB/T 30279-2013 信息安全技术 安全漏洞等级划分指南

GB/T 35273-2020 信息安全技术 个人信息安全规范

GB/T 39335-2020 信息安全技术 个人信息安全影响评估指南

YD/T 1730-2008 电信网和互联网安全风险评估实施指南

YD/T 3801-2020 电信网和互联网数据安全风险评估实施方法

3 术语和定义

下列术语和定义适用于本文件。

3.1

个人信息 personal information

以电子或其他方式记录的，能够单独或结合其他信息，识别特定自然人身份或反映特定自然人活动情况的各种信息。

3.2 敏感数据 sensitive data

不当使用或未经授权被人接触或修改后，会产生不利于国家和组织的负面影响和利益损失，或不利于个人依法享有的个人隐私的所有数据。

3.3 脆弱性 vulnerability

包含各种软件漏洞和配置风险，是资产或资产组中存在的，可能被威胁利用而造成损害的薄弱环节，脆弱性一旦被威胁成功利用就可能对资产造成损害。

3.4 脆弱性扫描 vulnerability scanning

基于漏洞库和其他脆弱性扫描规则,过扫描等手段对指定的远程或者本地计算机系统的安全脆弱性进行检测,发现可利用漏洞的一种安全检测(渗透攻击)行为。

3.5 接口 interface

应用程序接口,是一组定义、程序及协议的集合,通过接口实现应用程序之间的相互通信。

3.6 数据防泄漏 data leakage prevention (DLP)

通过一定的技术手段,防止企业内部指定的数据或信息资产以违反规定的安全策略的形式而流出企业外部的一种防护技术。

4 数据安全评估概述

4.1 概述

电信网和互联网承载着全民身份信息、通信记录及敏感通信内容、网络运行数据、电信及互联网关键业务数据等重要数据资产,直接关系到国家安全、社会稳定和公民隐私。电信网和互联网目前由于多级分散式大数据中心框架、开源大数据生态系统部署、5G边缘计算/NFV等新型网络环境带来新的数据安全及隐私风险,在数据资产管理、数据资源多方存储、数据开放共享、数据溯源定责、数据业务安全等多方面存在突出安全问题,亟需提出针对电信网和互联网数据安全评估实施指南,有利于电信领域数据业务的安全、健康发展。

4.2 数据安全评估原则

4.2.1 关键数据原则

数据安全评估以业务中的关键数据资产作为评估工作的核心,把关键数据涉及的各类应用场景作为评估的重点。数据重要程度越高,数据安全事件一旦发生对业务或组织的影响程度越大,在评估工作中就越应将其作为重点对象,评估其在各应用场景中存在的威胁、脆弱性及相关安全风险。

4.2.2 场景依赖原则

数据安全评估工作依赖数据所涉及的各应用场景。

被评估数据的安全与其应用场景强相关,评估数据安全可评估数据在所涉及的各类应用场景下的安全风险,数据安全评估工作首先需要梳理数据所涉及的各类应用场景。然后在此基础上进一步分析数据应用时在场景中各主体及各主机间的活动可能存在的安全风险,进而确认评估工作的重点。

4.2.3 可控性原则

在数据安全评估过程中,可按照项目管理方法对过程、人员和工具等进行控制,以保证实施过程的可控和安全。

a) 服务可控性

评估方事先获得本单位负责相关工作的管理者的认可,明确需要得到被评估组织协作的工作内容,明确评估工作中相关的管理和技术人员任务,获得支持和配合,确保评估工作的顺利进行。

b) 人员与信息可控性

所有参与评估的人员签署保密协议,以保证项目数据的安全;对过程数据和结果数据严格管理,未经授权不得泄漏给任何单位和个人。

c) 过程可控性

可按照项目管理要求,成立项目实施团队,项目组长负责制,达到项目过程的可控。

d) 技术手段可控性

安全评估方所使用的技术评估手段可事先通告被评估方，并在项目实施前获得被评估方的许可，包括产品本身、测试策略等。

4.2.4 最小影响原则

从项目管理层面和技术层面，将评估工作对电信网和互联网及相关系统正常运行的可能影响降低到最低限度，对于需要进行攻击性测试的工作内容，需与用户沟通并进行应急备份，同时选择避开业务的高峰时间进行。

4.3 数据安全评估技术实施要点

数据安全评估是依据相关标准，对信息系统及由其处理、传输和存储的数据的保密性、完整性和可用性等安全属性进行评估的过程。

数据安全评估围绕着数据梳理和分类、存储加密、传输加密、权限管理、数据脱敏、日志审计、脆弱性管理、接口安全、数据防泄漏等技术要点展开。在评估过程中，需要充分考虑数据资产重要程度、安全需求、安全风险等与这些基本要素相关的各类属性，以此来评估技术要点的重要度。

4.4 数据安全评估技术实施流程

整个数据安全评估技术实施部分一般分为准备环境、实施现场评估、输出评估结果、问题整改、复评五个阶段。评估流程如下：

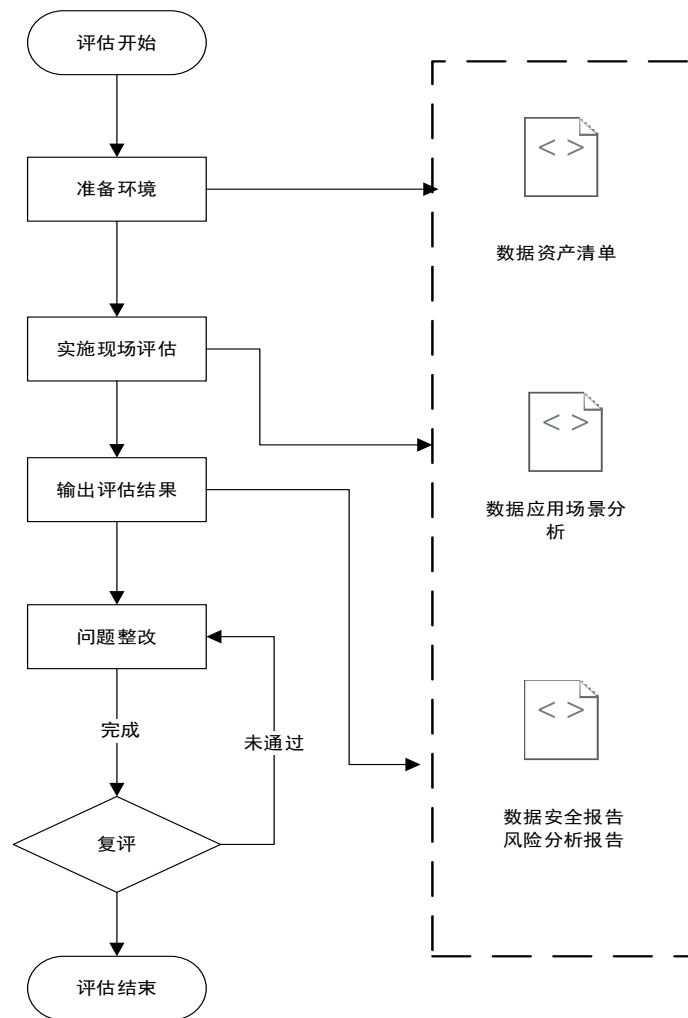


图1 数据安全评估技术实施流程

4.4.1 准备环境

为保证评估过程的有效进行,在进行评估之前需要评估机构及被评估组织进行对应的评估准备工作。

评估机构组建适当的数据安全评估方,并配合技术手段辅助完成,以支持整个数据安全评估过程的推进,以及评估工作的有效展开。采用的评估手段不影响被评估组织的业务运行。评估方可由组织管理层、法务、安全、相关业务骨干、技术和管理人员组成,必要时可聘请相关专业的专家组成专家小组。

被评估组织在评估之初,可根据评估方提供的评估清单进行对应的评估环境准备,并对评估环境进行充分有效的说明,以保证评估方有效顺利开展评估工作。具体可包括:

- a) 必要的办公环境支持,包括出入证、工位、互联网接入、内网接入等;
- b) 待评估业务系统的网络拓扑结构与安全域划分;
- c) 开展评估工作需要的其他信息。

评估方与被评估组织可在正式评估之前就被评估组织准备的环境进行沟通,形成一致意见。

4.4.2 实施现场评估

评估方在实施现场进行评估工作时,为保证评估工作的顺利开展,可通过召开启动会的形式了解被评估组织的评估环境,在充分了解评估环境的基础上展开评估工作。

评估方在实施现场可按照第5章的数据安全评估实施指南进行展开,可采取会议、询问、配以技术手段对评估环境进行检查和核实等方式开展评估工作。被评估组织在评估过程中宜积极配合评估方的工作,并及时对评估过程中出现的问题进行有效解决。

4.4.3 输出评估结果

现场检查完后，评估方可按照数据安全评估要求对所涉及应用场景下的各类问题进行汇总，并对问题引起的风险进行说明，根据风险等级及严重程度输出分项评分结果。同时评估方与被评估组织也需要针对评估结果交换意见，就问题及风险情况达成一致意见，最终完成数据安全评估报告。报告内容可包括评估工作总结、评分表、评估发现的主要问题、风险汇总及整改措施等内容。

4.4.4 问题整改

被评估组织可根据专家评估报告，组织有关部门制定整改计划，落实整改措施。被评估组织可在整改过程中，对整改计划完成情况进行及时的总结，必要时可修改整改计划。

4.4.5 复评

被评估组织在规定时间内完成整改之后，向评估方提出复评申请。复评时，被评估组织可提供整改工作报告，部分整改和未完成整改的项目可逐项说明原因。评估方也可对现场评估发现的问题举一反三进行查评，结束后可提交数据安全复查评估报告。

5 数据安全评估技术实施方法

5.1 概述

数据安全评估技术实施方法是建议评估方实施评估时采用的方法。评估目的是指该项评估的具体目标；评估方法是建议评估方采用的具体评估方法；评估能力是建议评估方具备的技术能力。

5.2 数据梳理和分类

5.2.1 评估目的

评估数据资产梳理和分类的覆盖率、准确率。

5.2.2 评估方法

数据梳理和分类的评估方法包括：

- a) 发现数据资产并生成资产清单。如果准备了数据存管系统的访问条件，建议采用遍历扫描的方式，如果未准备数据存管系统的访问条件，可采取人工核查等方式；
- b) 根据数据资产清单对数据进行自动分类、人工分类和核查，并建立数据分类结果清单；
- c) 读取被评估组织提供的数据资产分类清单；
- d) 比对上述两个清单，计算资产梳理和分类的覆盖率、准确率。

5.2.3 评估能力

数据梳理和分类应具备的能力如下：

- a) 支持扫描文件系统、关系型数据库、分布式数据库、非关系型数据库等数据存管系统，建立数据资产清单；
- b) 对个人信息、法人信息以及其他重要敏感数据具备自动分类的能力，可管理自动分类功能，可手动调整分类结果；
- c) 支持手动导入已有分类结果；
- d) 兼容本行业数据梳理和分类的要求，并可对分类要求进行管理。

5.3 存储加密

5.3.1 评估目的

评估敏感数据在存储时是否采用适当的加密措施。

5.3.2 评估方法

存储加密的评估方法包括：

- a) 根据数据分类结果确定需要采取存储加密措施的数据资产清单，并确定对应的加密策略。加密策略包括：
 - 1) 加密粒度：字段、表空间、文件、磁盘分区等；
 - 2) 加密算法：国家认可算法；
 - 3) 加密强度：密钥长度；
 - 4) 解密权限控制策略。
- b) 对需要加密的数据，根据加密策略，采取技术手段分析是否加密、加密粒度是否符合策略设置、加密强度是否符合策略设置、解密权限控制策略设置是否生效。

5.3.3 评估能力

存储加密应具备的能力如下：

- a) 支持字段、表空间、文件、磁盘分区等加密粒度的检测能力；
- b) 支持对加密强度的检测；
- c) 支持对加密算法的检测；
- d) 支持对解密权限控制策略的检测；
- e) 兼容本行业对数据加密的要求，可对加密要求进行管理。

5.4 传输加密

5.4.1 评估目的

评估敏感数据在传输时是否采用适当的加密措施。

5.4.2 评估方法

传输加密的评估方法包括：

- a) 根据数据分级结果确定需要采取传输加密措施的传输通道清单，并确定对应的加密策略。加密策略包括：
 - 1) 加密方法：应用加密、链路加密等；
 - 2) 加密算法：国家认可算法，满足数据加密、数据完整性检验和数据可用性检验；
 - 3) 加密强度：密钥长度；
 - 4) 认证策略：收发双方身份认证策略。
- b) 对需要加密传输的数据，根据加密策略，采取技术手段分析是否加密、加密方法设置是否生效、加密强度是否符合策略设置、认证策略设置是否生效。技术手段可包括：
 - 1) 网络嗅探；
 - 2) 导入通信密钥，进行通信内容解密；
 - 3) 模拟传输。

5.4.3 评估能力

传输加密应具备的能力如下：

- a) 支持应用级、链路级加密的检测能力；

- b) 支持对加密强度的检测；
- c) 支持对加密算法的检测；
- d) 支持身份认证策略的检测；
- e) 兼容本行业传输加密的要求，可对加密要求进行管理。

5.5 权限管理

5.5.1 评估目的

评估数据的访问权限管理是否设置生效。

5.5.2 评估方法

权限管理的评估方法包括：

- a) 根据数据资产分类结果，梳理数据访问场景，确定各类数据需要的权限管理策略，获得权限策略清单。权限管理策略可包括如下方面：
 - a) 权限管理粒度：库级、文件级、表级、字段级、行级、执行语句级等；
 - b) 访问权限：读取、修改、新增、删除等；
 - c) 主体认证方式：单因子、多因子、金库模式等。
- b) 数据访问场景可包括如下方面：
 - 1) 运维人员访问数据；
 - 2) 应用系统访问数据；
 - 3) 用户在应用上访问数据；
 - 4) 数据分析人员访问数据。
- c) 通过技术手段获取被评估系统现有的权限管理策略，与权限策略清单对比，分析策略是否正确被应用。可采用的技术手段包括：
 - 1) 采用账号权限扫描或查看配置参数等方式，获取系统类账号的权限；
 - 2) 模拟登入数据存管系统，分析主体认证机制、入口控制策略是否生效，口令强度是否符合策略设置；
 - 3) 尝试SQL注入、漏洞利用、越权操作等非法数据访问，评估现有系统能否拒绝非法访问。

5.5.3 评估能力

权限管理应具备的能力如下：

- a) 具备账号权限扫描能力；
- b) 具备登入数据源能力；
- c) 具备模拟数据访问行为的能力。

5.6 数据脱敏

5.6.1 评估目的

评估敏感数据在各种使用场景中是否被正确脱敏。

5.6.2 评估方法

数据脱敏的评估方法包括：

- a) 根据数据资产分类结果，梳理数据使用场景，确定需要脱敏的数据和使用场景，并确定对应的脱敏策略。脱敏场景可覆盖如下：
 - 1) 研发、测试、培训场景；
 - 2) 数据发布场景，包括网页、APP等；
 - 3) 数据共享场景；
 - 4) 实时运维、实时分析场景；
 - 5) 系统访问场景。
- b) 对需要脱敏的场景，根据脱敏策略，采取技术手段分析是否脱敏、脱敏算法是否符合策略设置、脱敏后数据的不可复原性是否符合策略设置。可采用的技术手段包括：
 - 1) 使用数据识别和分类技术扫描数据存管系统、脱敏数据、发布的网页等，以评估是否包含直接标识符和准标识符；
 - 2) 使用脱敏数据与明文数据的对比分析技术，评估脱敏数据是否具有足够的不可复原性；
 - 3) 评估脱敏软件安全特性及其参数配置。
- c) 根据上述分析结果，评估脱敏措施是否符合相关政策、法律、法规和标准。

5.6.3 评估能力

数据脱敏应具备的能力如下：

- a) 支持对多种数据源、网页等的敏感数据识别和分类能力；
- b) 具有对脱敏数据抗分析强度评估能力；
- c) 兼容本行业数据脱敏的要求，并可对脱敏要求进行管理。

5.7 日志审计

5.7.1 评估目的

评估对敏感数据的访问是否被正确审计，对数据的未授权访问等攻击行为是否被正确识别并告警。

5.7.2 评估方法

日志审计的评估方法包括：

- a) 根据数据资产分类结果，梳理数据访问场景，确定各类数据需要的审计策略，获得审计策略清单。审计策略可包括：操作时间、操作主体、操作类型、操作对象、操作结果等信息。数据访问场景覆盖数据生命周期各环节，可包括：
 - 1) 运维人员访问数据；
 - 2) 应用系统访问数据；
 - 3) 用户在应用上访问数据；
 - 4) 数据分析人员访问数据；
 - 5) 数据共享和外发；
 - 6) 数据访问接口。
- b) 通过技术手段获取被评估系统现有的审计能力，与审计策略清单对比，分析策略是否正确被应用。可采用的技术手段包括：
 - 1) 读取被测系统历史审计日志，分析其字段完整性、场景覆盖、保存时间等方面是否符合要求；
 - 2) 模拟正常访问、SQL注入、漏洞利用、越权操作等非法数据访问，评估现有系统能否记录及告警；
 - 3) 读取被测系统历史报表，分析审计周期、对数据非法访问、数据篡改等数据安全事件的识别能力是否符合要求。

5.7.3 评估能力

日志审计应具备的能力如下：

- a) 支持基于网络流量分析的数据访问审计和风险识别能力，以记录数据访问行为；
- b) 具有基于日志的数据安全事件识别能力；
- c) 支持历史日志的读取，可自动判断历史日志格式；
- d) 兼容本行业数据审计的要求，并可对审计要求进行管理。

5.8 脆弱性管理

5.8.1 评估目的

评估软件系统脆弱性的发现和加固情况是否满足数据安全要求。

5.8.2 评估方法

脆弱性管理的评估方法包括：

- a) 通过调研、网络扫描等方式生成待评估系统清单。重点关注三类系统：
 - 1) 数据存管系统；
 - 2) 直接访问数据的系统；
 - 3) 与数据存管系统存在网络通道的系统。
- b) 通过网络端口扫描、漏洞利用测试、检查系统配置等技术方法，发现并验证脆弱性；
- c) 与被评估方现有漏洞管理系统相比对，将发现的脆弱性标记为：未掌握、已掌握、已加固；
- d) 根据分析结果，评估脆弱性管理现状。

5.8.3 评估能力

脆弱性管理应具备的能力如下：

- a) 支持各类操作系统、数据库、中间件、HADOOP系统的脆弱性扫描；
- b) 漏洞库可包括CVE/CNNVD等公开漏洞；
- c) 支持SQL注入、XSS跨站攻击等模拟入侵；
- d) 定期更新漏洞库，具有扫描最新脆弱性的能力。

5.9 接口安全

5.9.1 评估目的

评估数据访问接口的安全措施是否生效。

5.9.2 评估方法

接口安全的评估方法包括：

- a) 检查接口开发规范、交互协议等方式，评估接口是否符合要求，并获取接口清单；
- b) 采取以下技术方法，分析各个接口的安全性：
 - 1) 模拟接口调用，评估接口的身份鉴别、访问控制、授权策略、审计等安全措施是否生效，评估接口是否具有过滤或限制不安全参数的能力；
 - 2) 检查接口调用日志、配置参数等方式，评估对接口访问的审计能力；
 - 3) 通过检查配置参数、分析网络流量等方式，评估跨安全域的接口调用是否采用了安全通道、加密传输等安全措施；

- 4) 通过模拟新增接口, 评估是否具备新增接口的安全审批机制;
 - 5) 通过接口扫描, 发现是否有未纳入管理的接口。
- c) 根据分析结果, 评估接口安全管理现状。

5.9.3 评估能力

接口安全应具备的能力如下:

- a) 具有模拟接口调用及新增接口的能力;
- b) 支持RESTFUL、WEB SERVICE等服务接口;
- c) 具有接口日志读取和分析能力;
- d) 具有接口发现能力。

5.10 数据防泄漏

5.10.1 评估目的

评估基于审计日志发现数据泄漏的综合分析能力; 评估防止敏感数据通过网络、存储介质被泄漏的能力。

5.10.2 评估方法

数据防泄漏的评估方法包括:

- a) 采用模拟发送、复制数据等方式, 评估是否会阻止非法的数据泄漏行为;
- b) 读取历史日志数据, 分别进行个人行为、应用行为、数据流动等画像, 进而分析潜在的数据泄漏行为;
- c) 对比现有数据泄漏检测结果, 评估被评估方数据泄漏检测能力。

5.10.3 评估能力

数据防泄漏应具备的能力如下:

- a) 具有通过USB、打印、光驱等介质模拟数据外发的能力, 以及通过邮件、即时通讯工具、FTP、WEB、网盘等网络途径模拟数据外发的能力;
- b) 具有基于历史日志的数据访问行为画像、数据泄漏事件分析能力。

6 数据安全评估技术实施环境

6.1 概述

在使用技术手段进行评估之前, 评估方与被评估方协商准备评估所需的技术环境, 以保障评估过程顺利执行。

6.2 数据梳理和分类

数据梳理和分类可提供:

- a) 数据存管系统的访问条件, 便于进行数据扫描;
- b) 历史数据分类结果, 便于比对梳理结果。

6.3 存储加密

存储加密可提供:

- a) 存储加密清单和加密策略;
- b) 验证存储加密效果的环境。

6.4 传输加密

传输加密可提供：

- a) 现有加密传输规范清单；
- b) 能够验证传输加密效果的环境。

6.5 权限管理

权限管理可提供现有账号与权限分配清单。

6.6 数据脱敏

数据脱敏可提供：

- a) 现有脱敏场景和策略；
- b) 能够验证现有数据脱敏策略的环境。

6.7 日志审计

日志审计可提供：

- a) 现有日志审计策略清单；
- b) 能够验证现有日志审计策略的环境。

6.8 脆弱性管理

脆弱性管理可提供：

- a) 评估系统脆弱性扫描范围；
- b) 脆弱性扫描的环境。

6.9 接口安全

接口安全可提供：

- a) 接口安全实现的说明文档；
- b) 验证接口安全的环境。

6.10 数据防泄漏

数据防泄漏可提供：

- a) 需要数据防泄漏保护的系统清单；
 - b) 验证数据防泄漏保护效果的环境。
-